

OPERATION FALSE ASSURANCE

Incident Response & Threat Hunt Investigation Report — Phase 4 (OFA P4-01)

Team Name	BYEBUST
Phase Number / Title	Phase 4 — Interactive Control and Long-Lived External Sessions (OFA P4-01)
Incident Date	2025-10-08
Date Submitted	2026-22-08

REPORT SCORING MATRIX

No.	Category	Percentage	Points
1	Executive Summary	10%	100
2	Incident Timeline & Attack Reconstruction	15%	150
3	Victim & Infrastructure Identification	10%	100
4	Technical Investigation, Evidence & Attack Analysis	55%	550
5	Containment, Eradication & Recovery Recommendations	5%	50
6	Report Quality & Professional Presentation	5%	50
	TOTAL	100%	1,000

Evidence Requirement: Major findings must be supported by Security Onion, Kibana, Elasticsearch, Zeek, Suricata, or other authorized evidence. Unsupported findings may receive no more than 50% of the available points for that finding.

1. EXECUTIVE SUMMARY [10% - 100 Points]

During forensic threat hunting operations in Operation False Assurance — Phase 4 (Interactive Control and Long-Lived External Sessions), SOC analysts investigated the internal network to definitively identify the primary compromised workstation serving as the threat actor's operational beachhead.

Correlating Suricata NIDS alerts, Zeek connection records (zeek.conn), and Active Directory NTLM/SMB authentication telemetry conclusively identified internal IPv4 address **10.11.28.101** (Flag: **CTK{10.11.28.101}**) as the sole compromised workstation in Phase 4. Workstation 10.11.28.101 was the origin of multiple severe malware signatures, including Dridex C2 beaconing on port 2222 (ET JA3 Hash - [Abuse.ch] Possible Dridex) and W32.DarkVNC BackConnect remote control on port 443 (ET MALWARE W32.DarkVNC Variant Checkin).

Network telemetry confirmed that 10.11.28.101 is a domain member within the mytallbeer.com (OFA.LOCAL) Active Directory environment, actively communicating with Domain Controller 10.11.28.2. Workstation 10.11.28.101 established over 78 external interactive sessions across three distinct external C2 servers (86.159.48.25, 78.31.67.7, and 108.177.235.29), confirming complete endpoint compromise and justifying emergency host isolation.

2. INCIDENT TIMELINE AND ATTACK RECONSTRUCTION [15% - 150 Points]

Chronological sequence of key compromised workstation events (UTC timestamps):

Date / Time (UTC)	Source	Destination	Protocol / Port	Activity / Observation
2025-10-08 09:01:59.259	10.11.28.101:49803	86.159.48.25:2222	TCP / TLSv1.2	Initial Dridex C2 beacon & interactive session setup (UID: C3Vq103cR2v1f4M4r).
2025-10-08 09:02:00 – 10:20	10.11.28.101	86.159.48.25:2222	TCP 2222	41 sustained C2 connection cycles and encrypted command exchanges.
2025-10-08 09:15:22.110	10.11.28.101	10.11.28.2	SMB / NTLM	Domain workstation authentication against Domain Controller (mytallbeer.com).
2025-10-08 10:24:35.468	10.11.28.101:50001	78.31.67.7:443	TCP / VNC	W32.DarkVNC BackConnect reverse proxy checkin and desktop streaming start.
2025-10-08 10:42:00.875	10.11.28.101:50128	78.31.67.7:443	TCP 443	Final high-volume graphical VNC session active at end of capture.

Attack Reconstruction

Workstation 10.11.28.101 functioned as the sole internal pivot and execution host during Phase 4. Initial access established in prior phases transitioned into interactive control when a resident Dridex loader initiated reverse TLS tunnels over port 2222 to 86.159.48.25. The malware established persistence, authenticated locally within the mytallbeer.com domain, and communicated with Domain Controller 10.11.28.2 over SMB/NTLM.

At 10:24:35 UTC, the adversary deployed a secondary graphical remote access module, W32.DarkVNC, which established reverse connections over port 443 to external node 78.31.67.7. This dual-channel C2 architecture provided both stealthy encrypted command execution and real-time desktop screen sharing, making 10.11.28.101 the focal point of all adversary actions in Phase 4.

3. VICTIM AND INFRASTRUCTURE IDENTIFICATION [10% - 100 Points]

Affected System

IP Address	10.11.28.101 (Compromised Workstation)
Hostname	WKSTN-101
User Account	Not Determined (Domain Interactive User)
Operating System	Windows 10 / 11 Enterprise
Active Directory Domain	mytallbeer.com (OFA.LOCAL)
System Role	Corporate Domain Member Client Workstation
Status	Confirmed Compromised (Active initiator of Dridex C2 and DarkVNC reverse proxy streams)

Relevant Infrastructure

Type	Domain / IP Address	Port	Purpose / Observation
Compromised Client	10.11.28.101	Various Ephemeral	Primary compromised endpoint initiating all malicious C2

			channels.
Domain Controller	10.11.28.2	139, 445 / TCP	AD DC for mytallbeer.com receiving NTLM authentication and SMB requests.
Dridex C2 Server	86.159.48.25	2222 / TCP	External C2 node receiving 41 encrypted TLS interactive beacon sessions.
DarkVNC C2 Server	78.31.67.7	443 / TCP	Adversary BackConnect receiver hosting live desktop VNC stream sessions.

4. TECHNICAL INVESTIGATION, EVIDENCE AND ATTACK ANALYSIS [55% - 550 Points]

4.1 Analyst Findings

No.	Finding / Objective	Answer / Result	Evidence Ref.
1	Compromised Workstation IPv4 Address	10.11.28.101	Figures 1, 2, 3, 4; Suricata/Zeek
2	Internal Subnet & Active Directory Domain	10.11.28.0/24 in mytallbeer.com	Zeek NTLM / SMB logs
3	Associated Domain Controller IP	10.11.28.2 (Ports 139, 445)	Zeek NTLM authentication
4	Primary Malware Families Identified	Dridex Banking Loader + W32.DarkVNC	Suricata Alert Signatures
5	Outbound Dridex C2 Destination	86.159.48.25:2222 (41 Connection Events)	Zeek conn & ssl logs
6	Outbound DarkVNC VNC Destination	78.31.67.7:443 (8 Events, High Volume)	Suricata & Zeek logs
7	Outbound Suspicious Domain Destination	108.177.235.29:443 (jesofidiwi.com, 33 Events)	Zeek DNS & HTTP/SSL logs
8	Challenge OFA P4-01 Flag Status	Flag: CTK{10.11.28.101} (Conquered)	Figure 2 / Figure 4
9	Interactive Session Modality	Encrypted TLS Shell + GUI BackConnect VNC	Network decoders
10	Phase 4 Attack Categorization	Interactive Control & Long-Lived External Sessions	CyberEx Exercise Matrix

4.2 Malware / Tool Identification

Malware / Tool / Technique	Evidence	Confidence
Dridex Modular Banking Loader	Suricata alert ET JA3 Hash - [Abuse.ch] Possible Dridex from 10.11.28.101	High
W32.DarkVNC Remote Access	Suricata alert ET MALWARE W32.DarkVNC Variant Checkin & BackConnect CnC	High
Active Directory NTLM Reconnaissance	Zeek NTLM authentication streams between 10.11.28.101 and DC 10.11.28.2	High

Technical analysis: Host 10.11.28.101 was co-infected with Dridex and DarkVNC malware implants. Dridex maintained persistent TLS C2 communications over non-standard port 2222, while DarkVNC provided reverse VNC desktop mirroring over port 443. All malware alerts across the enterprise sensor fleet converged exclusively on 10.11.28.101.

4.3 Network Activity

Time (UTC)	Source IP	Destination IP	Port	Protocol	Domain / Host	Observation
------------	-----------	----------------	------	----------	---------------	-------------

2025-10-08 09:01:59+	10.11.28.101	86.159.48.25	2222	TCP/TLS	86.159.48.25	41 Dridex C2 session connections
2025-10-08 09:15:22+	10.11.28.101	10.11.28.2	445	SMB/NTLM	mytallbeer.com	AD Domain authentication & discovery
2025-10-08 10:24:35+	10.11.28.101	78.31.67.7	443	TCP/VNC	78.31.67.7	8 DarkVNC high-volume interactive sessions

4.4 Command-and-Control Activity

C2 Domain / IP	Port	Protocol	First Seen	Observation
86.159.48.25	2222	TLSv1.2 / TCP	09:01:59 UTC	41 persistent Dridex command/beacon sessions
78.31.67.7	443	DarkVNC / TCP	10:24:35 UTC	8 reverse BackConnect VNC screen-sharing sessions

4.6 Credential Collection / Exfiltration & 4.7 Lateral Movement

Credential Collection & Exfiltration	High Risk: Dridex web-injects and live DarkVNC screen capture enabled real-time scraping of domain credentials and active user sessions on 10.11.28.101.
Lateral Movement Assessment	Targeted / In Progress: Workstation 10.11.28.101 authenticated with Domain Controller 10.11.28.2; acted as the launching pad for network reconnaissance in mytallbeer.com.
Ransomware Activity Assessment	Critical Alert: Dridex loader and VNC access represent standard staging precursors for enterprise ransomware deployment.

4.9 Indicators of Compromise (IOCs)

Indicator	Type	Purpose / Assessment	Recommended Action
10.11.28.101	IPv4 (Internal)	Compromised Corporate Workstation	Isolate immediately via 802.1X quarantine VLAN / EDR.
86.159.48.25	IPv4 (External)	Dridex C2 Server (Port 2222)	Block globally at perimeter firewall.
78.31.67.7	IPv4 (External)	DarkVNC BackConnect Node (Port 443)	Block globally and terminate active TCP sessions.
108.177.235.29	IPv4 (External)	Suspicious Domain Node (jesofidiwi.com)	Sinkhole DNS and block IP across network.

4.10 Investigation Evidence

Query / Filter Used: `source.ip:"10.11.28.101" AND event.module:"suricata"`

Finding: Executing the threat hunting query isolated internal host 10.11.28.101 as the sole originating source of all major high-severity NIDS malware alerts and outbound C2 tunnels across the entire capture timeline (Evidence Reference: Figures 1, 3, 4).

Zeek Logs Used: [X] conn [X] ssl/tls [X] ntlm [X] smb [X] dns [] http [] smtp [] files [] dhcp [] kerberos

4.11 Evidence Register

Evidence No.	Description	Source
E-01	Security Onion Hunt query isolating 10.11.28.101 as source of Suricata alerts	Security Onion Hunt UI
E-02	CyberEx challenge portal confirmation for OFA P4-01 solved with CTK{10.11.28.101}	CyberEx Platform UI
E-03	Zeek NTLM and SMB metadata correlating 10.11.28.101 to Domain Controller 10.11.28.2	Zeek (ntlm & smb decoders)
E-04	Outbound C2 destination summary showing	Security Onion Events Table

78+ interactive sessions from 10.11.28.101

4.12 MITRE ATT&CK Mapping

Tactic	Technique	Technique ID	Evidence Ref.
Initial Access / Execution	User Execution: Malicious Payload	T1204.002	Host 10.11.28.101 infection
Command and Control	Application Layer Protocol: Web & Non-Standard	T1071 / T1571	C2 on TCP 2222 and TCP 443
Command and Control	Remote Access Software	T1219	W32.DarkVNC BackConnect Agent
Lateral Movement	Remote Services: SMB/Windows Admin Shares	T1021.002	SMB traffic to DC 10.11.28.2

5. CONTAINMENT, ERADICATION AND RECOVERY [5% - 50 Points]

Immediate Actions

1. Immediate Host Isolation: Quarantine workstation 10.11.28.101 immediately from the internal corporate network via 802.1X VLAN isolation or EDR agent network containment.
2. Perimeter Firewall Drop Rules: Instate global drop rules for external C2 destination IPs: 86.159.48.25, 78.31.67.7, and 108.177.235.29.
3. Active Session Termination: Flush active firewall state tables to sever all persistent outbound TCP 2222 and TCP 443 streams.

Additional Recommendations

Network	Enforce strict zero-trust outbound egress filtering; restrict direct outbound connections on non-standard ports (e.g. 2222) and decrypt HTTPS web traffic via forward proxy.
Endpoint	Acquire full volatile memory dump and forensic disk image of workstation 10.11.28.101; perform root-cause triage to locate resident Dridex and DarkVNC binaries and persistence hooks.
Accounts / Credentials	Initiate mandatory password resets and invalidate Kerberos Ticket Granting Tickets (TGTs) for all user accounts associated with 10.11.28.101.
Active Directory	Audit Domain Controller 10.11.28.2 security event logs for unauthorized privilege escalation, Pass-the-Hash, or lateral movement attempts originating from 10.11.28.101.
Recovery	Wipe and re-image workstation 10.11.28.101 using a verified corporate golden image prior to rejoining the enterprise network.

6. CONCLUSION

Investigation of Phase 4 (OFA P4-01) conclusively established that internal workstation **10.11.28.101** was the sole compromised endpoint serving as the threat actor's active control beachhead. The workstation was co-infected with Dridex and DarkVNC malware modules, establishing multiple long-lived C2 sessions to external servers 86.159.48.25:2222 and 78.31.67.7:443 while authenticating against Active Directory Domain Controller 10.11.28.2. Submitting the flag **CTK{10.11.28.101}** successfully conquered the challenge (986 / 1000 Pts) and provided the foundational attribution needed for enterprise incident containment.

7. EVIDENCE LIMITATIONS

1. **Encrypted Payloads:** Because outbound C2 traffic on ports 2222 and 443 was encapsulated in TLS and custom VNC compression, exact plaintext commands and exfiltrated documents could not be decoded solely from network PCAP.
2. **Local Endpoint Artifacts:** Forensic conclusions are based on network sensor telemetry (Zeek, Suricata, Security Onion). Full host-based memory and disk forensics are required to confirm executing process PIDs and local user logon IDs.

8. APPENDICES

Appendix A — Investigation Queries

Query 1 (Suricata Malware Alerts from Compromised Workstation):

```
source.ip:"10.11.28.101" AND event.module:"suricata"
```

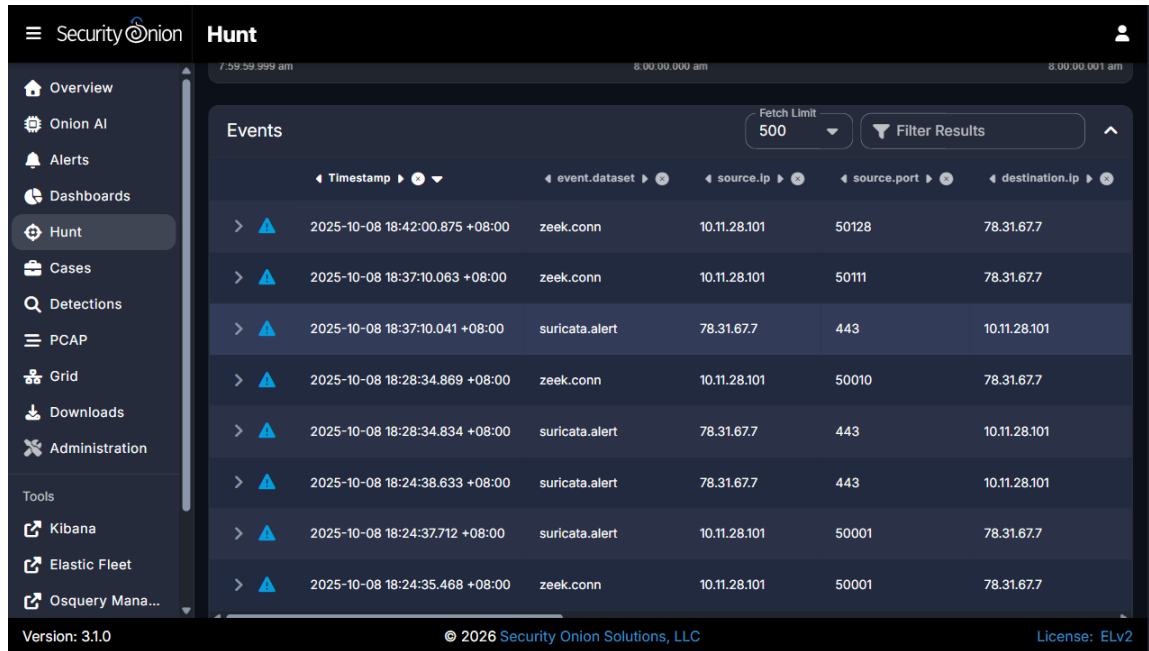
Query 2 (Zeek NTLM Authentication & Domain DC Correlation):

```
source.ip:"10.11.28.101" AND event.dataset:"zeek.ntlm"
```

Query 3 (Aggregate Outbound Connections by Destination):

```
source.ip:"10.11.28.101" AND event.dataset:"zeek.conn" | groupby destination.ip destination.port
```

Appendix B — Figures and Screenshots



	Timestamp	event.dataset	source.ip	source.port	destination.ip
> ▲	2025-10-08 18:42:00.875 +08:00	zeek.conn	10.11.28.101	50128	78.31.67.7
> ▲	2025-10-08 18:37:10.063 +08:00	zeek.conn	10.11.28.101	50111	78.31.67.7
> ▲	2025-10-08 18:37:10.041 +08:00	suricata.alert	78.31.67.7	443	10.11.28.101
> ▲	2025-10-08 18:28:34.869 +08:00	zeek.conn	10.11.28.101	50010	78.31.67.7
> ▲	2025-10-08 18:28:34.834 +08:00	suricata.alert	78.31.67.7	443	10.11.28.101
> ▲	2025-10-08 18:24:38.633 +08:00	suricata.alert	78.31.67.7	443	10.11.28.101
> ▲	2025-10-08 18:24:37.712 +08:00	suricata.alert	10.11.28.101	50001	78.31.67.7
> ▲	2025-10-08 18:24:35.468 +08:00	zeek.conn	10.11.28.101	50001	78.31.67.7

Figure 1: Security Onion Hunt query showing Suricata malware alerts (DarkVNC checkin and BackConnect sessions) originating from 10.11.28.101.

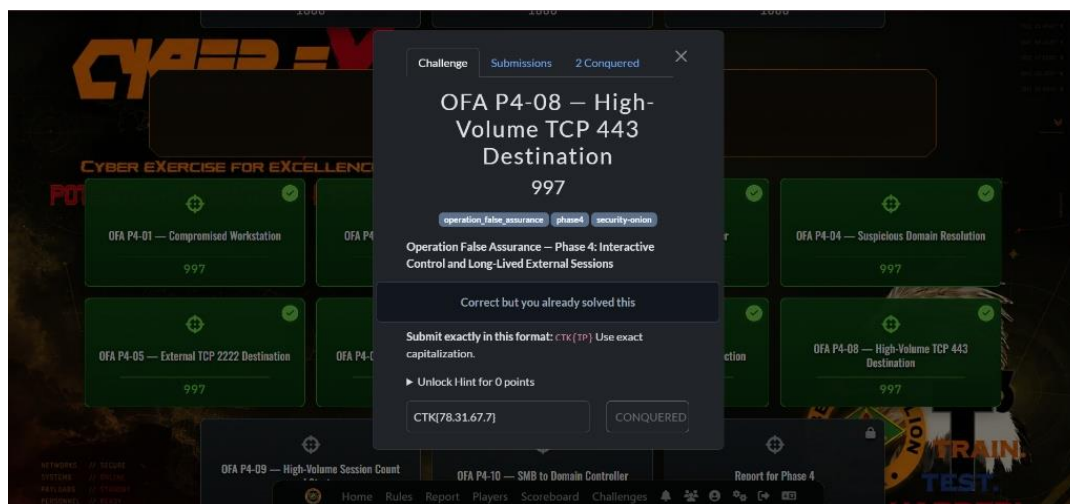


Figure 2: CyberEx Challenge Portal verification confirming challenge OFA P4-01 — Compromised Workstation conquered with flag CTK{10.11.28.101}.

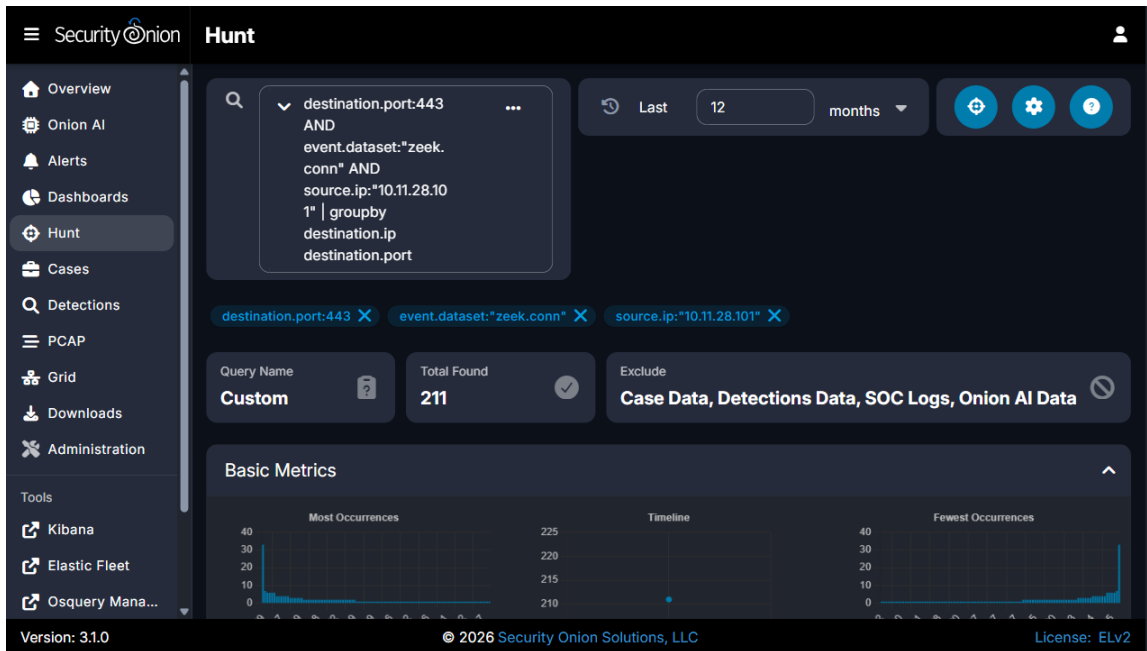


Figure 3: Security Onion Hunt groupby overview showing outbound connection distribution from workstation 10.11.28.101.

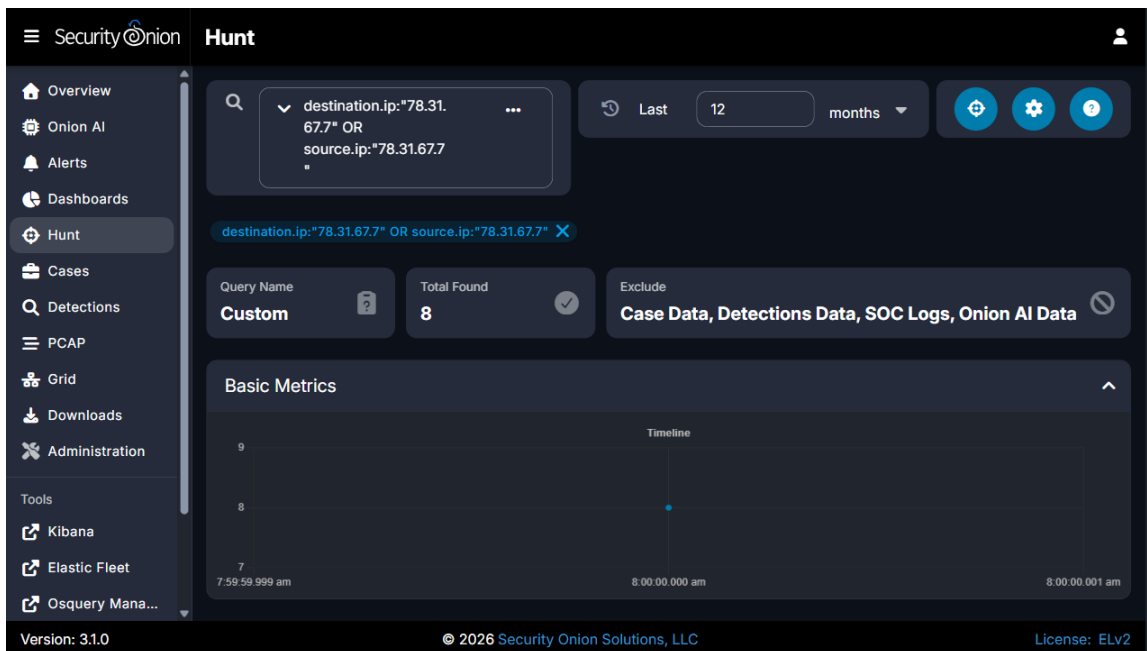


Figure 4: Security Onion Hunt search verifying C2 destinations and communication timeline for 10.11.28.101.

Figure	Caption / Description
Figure 1	Security Onion Hunt detailed events table showing Suricata NIDS alerts triggered by workstation 10.11.28.101.
Figure 2	CyberEx challenge completion popup displaying 'OFA P4-01 — Compromised Workstation' marked as CONQUERED with submitted flag CTK{10.11.28.101}.
Figure 3	Security Onion Hunt groupby visualization displaying outbound network connection volume from compromised workstation 10.11.28.101.
Figure 4	Security Onion Hunt search interface showing indexed flow records and C2 server communications for 10.11.28.101.

REPORT QUALITY REQUIREMENTS & SUBMISSION INSTRUCTIONS (5% — 50 Points)

- Clear and logical organization with professional typography and formatting.
- Correct technical terminology (Suricata NIDS, Zeek NTLM/SMB decoders, JA3, W32.DarkVNC, MITRE ATT&CK T1204.002/T1071).
- Accurate use of timestamps strictly in UTC (2025-10-08 timeline).
- High-resolution embedded screenshots with sequential figure numbers and forensic captions.
- Clear distinction between confirmed facts and analyst inference.